

SWF BUZZ — OLD BUZZ Identity / Login Migration Plan

Type	Audit + plan only. No source, config, dependency, database or Okta change was made
Date	2026-09-21
Decision under plan	Human users in SWF BUZZ use the same identity and login model as OLD BUZZ : local Nostr keypair, NIP-42 (WebSocket), NIP-98 (HTTP), membership keyed by <code>community + pubkey</code> . No Okta, no Application User as human identity.
Inputs	OLD_BUZZ_AUTH_AND_COMMUNITY_FLOW_AUDIT.md, SWF_BUZZ_CURRENT_RUNTIME_AUDIT.md, plus the additional source reads listed in §2 and §21

Labels: **CONFIRMED** = read in source. **INFERRED** = follows from confirmed code, last hop not read. **UNCLEAR** = not confirmed. Paths: OLD: = `buzz/buzz/...`, SWF: = `buzz/swf buzz/...`.

0. Executive summary

- This migration is mostly a rewiring, not a rewrite.** SWF already contains a working Nostr client stack that was built against the Buzz relay: `RelayConnectionService` (NIP-42), channel/message/thread/reaction/DM/presence/typing/profile/moderation services, and a `SigningService` interface. Its only problem is *who supplies the key*: today an Okta-derived or dev key held in the webview. The target replaces that with a **Rust-held local key**, which is what OLD BUZZ does. The Nostr stack becomes the primary path again. **CONFIRMED** (SWF: `services/RelayConnectionService.ts:114-160`, `features/signing/types.ts`, `docs/E2E_TEST_RESULTS.md`).
- What is genuinely new work:** (a) a Rust identity module (generate / store / load / import / backup / sign), (b) a `TauriSigningService` that calls it, (c) onboarding screens (Vue), (d) relay-based invite create/claim with **NIP-98 including a payload tag** (SWF's `nip98.ts` has none), (e) a **SWF-owned deep-link scheme** and join flow, (f) relay/test configuration for a *closed* community with a known owner.
- Three constraints the earlier audits did not surface** (all **CONFIRMED**):
- The relay's invite landing page hardcodes** `buzz://join` and is only served when `BUZZ_WEB_DIR` is set. It would open the *installed OLD Buzz app*, not SWF. SWF must build its own `swfbuzz://join?...` link from the minted `code` and must not use the relay-returned `url`. (OLD: `web/src/features/invite/ui/InvitePage.tsx:113`; `crates/buzz-relay/src/router.rs:158-163, 239-246`)
- Owners cannot be created through the relay's normal flows.** `buzz-admin add-member` refuses `owner`; the only path is the `RELAY_OWNER_PUBKEY` env var at relay startup (or operator provisioning via `POST /operator/communities`). Also the local relay is **open by default** (`BUZZ_REQUIRE_RELAY_MEMBERSHIP` unset $\Rightarrow$ false) and neither variable is set in the current local `.env`, so invites have no effect until the relay is run closed with a known owner. (OLD: `crates/buzz-admin/src/main.rs:45-56`; `crates/buzz-relay/src/config.rs:244-247, 670-672`)
- A "community" is a relay tenant selected by the HTTP Host**, not something a user creates in the app. SWF's current "create community" button (HTTP backend) has no relay equivalent; a decision is needed (D-1).
- Most of what the request lists as "remove GitHub / remove local agents" is a no-op for SWF.** SWF contains no GitHub/project code and no local/managed-agent runtime (verified, §21-23). Those exclusions apply to what we must *not port*.
- SWF's backend (`swf buzz/backend`) becomes unnecessary for human flows**, because the relay already implements communities-by-tenant, membership, invites, channels, messages, threads, DMs and realtime.

Recommendation: freeze it, keep it out of the login path, remove after parity.

9. **Recommended order differs from your sketch in one place:** disable Okta (make it unreachable) early, but **delete** it only after the new path passes the test plan, so rollback stays possible (§31).

1. Current SWF authentication architecture

```
Human
└─ "Sign in with Okta" (LoginView)
  └─ Rust oidc::login: PKCE, system browser, JWKS verify SWF: src-tauri/src/auth/oidc.rs:350-477
    └─ (if SWF_BUZZ_BACKEND_URL) POST /api/session/bootstrap → users(okta_sub), Bearer session → OS keychain
      └─ returns {sub, email}
    └─ webview derives Nostr key = SHA-256("swf-buzz-local-dev-identity:" + sub) SWF: signingService.dev.ts
    └─ RelayConnectionService.connect() → NIP-42 AUTH (signed IN THE WEBVIEW) SWF: useAuth.ts:99
    └─ relay_members roster → resolveMyRole(pubkey) ⇒ authStatus="ready" SWF: useAuth.ts:110-116
Parallel (optional): Application User + Bearer token → HTTP UI (/community, /community-dm, invite services)
```

Full trace and file:line evidence: SWF_BUZZ_CURRENT_RUNTIME_AUDIT.md §1-§5. Key facts: the private key lives in webview memory; the `ready` gate is already relay/Nostr-based; the Application User path is additive.

2. OLD BUZZ authentication architecture (traced from source)

Concern	OLD BUZZ implementation	Evidence
Key generation	<code>Keys::generate()</code> in Rust when no key exists	OLD: desktop/src-tauri/src/app_state.rs:643 (load_file_or_generate)
Resolution order	<code>env BUZZ_PRIVATE_KEY</code> → OS keyring → <code>identity.key</code> file (0o600) → generate+save; startup placeholder is an ephemeral key replaced in <code>setup()</code>	app_state.rs:187-199, 251-297, 358
Storage types	<code>IdentityStorage { Ephemeral, SystemKeyring, LocalFile, Environment }</code>	identity_storage.rs:8-13
Keyring service	<code>buzz-desktop</code> (release), <code>buzz-desktop-dev[.scope]</code> (debug); the nsec is stored under a fixed name (<code>IDENTITY_KEY_NAME</code> , literal not re-read); a <i>migration marker</i> file distinguishes "first launch" from "keyring unreachable"	app_state_keyring.rs:9-23; app_state.rs:306-315, 507-560
Recovery states	<code>keyring_locked</code> (marker present, keyring unreachable → ephemeral key + "unlock and relaunch" screen), <code>identity_lost</code> (marker present, keyring empty → offer import or <code>persist_current_identity</code> for a new identity). <code>persist_current_identity</code> is lost-only by design	app_state.rs:61-91; commands/identity.rs:455-480
Import	<code>import_identity(nsec hex ncryptsec, password?)</code> ; NIP-49 decrypt in Rust	commands/identity.rs:337
Backup	NIP-49 <code>ncryptsec</code> , <code>srypt log_n 18</code> , password-encrypted, local file only, never sent to a relay (enforced by <code>egress_guard</code>); passphrase generator	key_backup.rs:1-30; commands/identity.rs:202-336
Show key	<code>get_nsec</code> returns bech32 to the UI on request	commands/identity.rs:191-197
Signing	<code>sign_event(kind, content, created_at, tags)</code> signs in Rust; no kind allowlist	commands/identity.rs:107-136

Concern	OLD BUZZ implementation	Evidence
NIP-42	create_auth_event(challenge, relay_url) → kind 22242 with tags relay, challenge; the WebSocket itself is native Rust (native_websocket.rs)	commands/identity.rs:641-666; relay verifies in crates/buzz-relay/src/handlers/auth.rs:87-92
NIP-98	TS builds kind 27235 with u, method, payload = sha256(body), nonce, signs via signRelayEvent (Rust)	OLD: desktop/src/shared/api/invites.ts:47-62
Sign-out	writes a reset sentinel; next boot wipes the identity	commands/identity.rs:537-560
Membership gate	after NIP-42: ban check → relay_members gate (require_relay_membership)	handlers/auth.rs:95-241
Invite	mint: owner/admin, NIP-98, returns v2.<32B>; claim: NIP-98 by joiner, inserts relay_members(..., 'member', 'invite')	api/invites.rs:284-515; relay_invite.rs:99-345
Deep link	buzz://join?relay=ws(s)&code=<code>[&policy_receipt], parsed in Rust, queued, acknowledged in TS after onboarding	deep_link.rs:344-362,630-642; desktop/src/shared/deep-link.ts:50-135

3. Target SWF authentication architecture

SWF Desktop (Tauri 2 + Vue 3)

└─ Tauri Rust identity layer

NEW src-tauri/src/identity/*

└─ resolve: env(dev only) → OS keyring (service "swf-buzz") → identity.key (00600) → generate

└─ holds Keys; exposes: get_identity, sign_event, nip44_*, get_nsec, import_identity,

└─ create/verify_backup, sign_out(reset)

└─ TauriSigningService (TS)

NEW implements the EXISTING SigningService interface

└─ getPublicKey / signEvent / nip44Encrypt / nip44Decrypt → invoke(...) (key never enters the webview)

└─ RelayConnectionService (TS, nostr-tools)

KEEP NIP-42 via signer.onauth

└─ nip98.ts + RelayInviteService (TS)

MODIFY/NEW NIP-98 (with payload tag) → /api/invites, /api/invites/claim

└─ Nostr feature services (channels, messages, threads, reactions, DM, presence, typing, profile, moderation)

KEEP (primary)

└─ Deep link `swfbuzz://join?relay=...&code=...`

NEW (replaces Okta scheme as the only scheme)

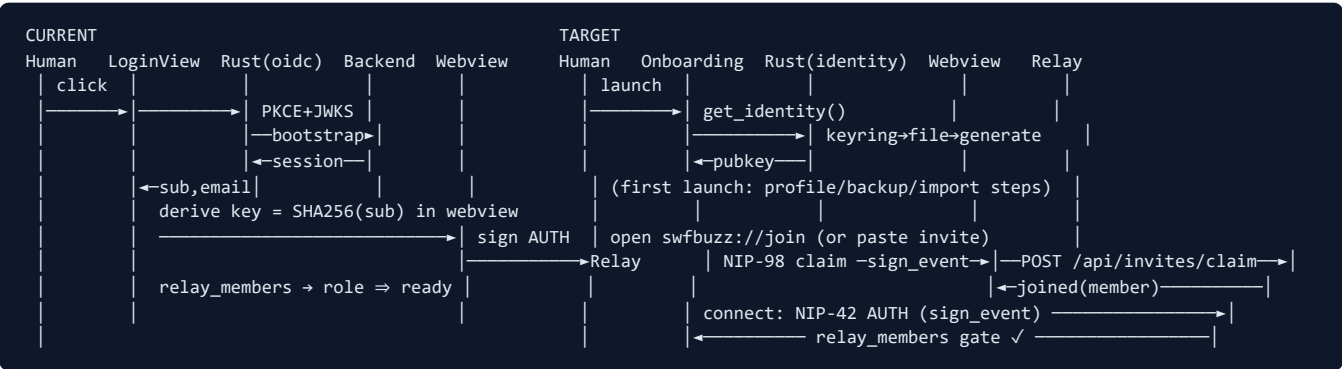
└─ NIP-42 (WS) / NIP-98 (HTTP)

└─ Buzz Relay (unchanged; read-only reference)

└─ relay_members(community_id, pubkey, role) · channel_members · events

No Okta, OAuth, email identity, password, or Application User for humans. **Agents:** unchanged (\$20).

4. Current vs target sequence



5. File-by-file Okta dependency map

Frontend (SWF: src/)

File	Current role	Target role	Action
views/LoginView.vue	"Sign in with Okta", dev-mode button, unreachable bunker step	Identity/onboarding entry (create / import key)	MODIFY (rewrite content)
views/OktaCallbackView.vue	browser Okta redirect target	none	REMOVE LATER
features/auth/useAuth.ts	orchestrates Okta → derived key → relay → role; silent resume via backend token	load local identity → connect relay → membership → ready	MODIFY (heavy)
features/auth/authService.okta.ts, authService.okta.browser.ts, oktaBrowserFlow.ts	Okta PKCE (native/browser)	none	REMOVE LATER
features/auth/authService.dev.ts	dev login with shared fixed key	dev only, or replaced by env identity override	UNKNOWN → prefer REMOVE LATER
features/auth/types.ts	AuthResult{applicationUserId,...}	{pubkey}	MODIFY
stores/session.ts	employeeEmail, applicationUserId, applicationUser, pubkey, role, authStatus	keep pubkey, communityRole, authStatus; drop Okta fields	MODIFY
services/ApiClient.ts	Bearer client for swf-buzz-backend, keychain token	none	REMOVE LATER
services/RealtimeService.ts	backend /ws push	none (relay subscriptions replace it)	REMOVE LATER
app/config.ts	oktaIssuer/ClientId, backendUrl	relayUrl (+ community list)	MODIFY
app/router/index.ts	guard needs isReady; /callback, /invite/:token, /community*	guard on identity+membership; /join; legacy routes become primary	MODIFY
views/InviteLandingView.vue	HTTP preview + Okta login + HTTP claim	in-app "Join community" (deep link / paste) using relay claim	REWRITE (reuse layout)
features/communities/{InviteService,useInvites}.ts	HTTP create/preview/claim/revoke	relay POST /api/invites, /claim; no preview, no revoke endpoint exists on the relay	REWRITE (keep composable shape)
features/communities/{pendingInvite,currentCommunity}.ts	sessionStorage token; current community id	pending join (relay+code); current relay/community	KEEP / MODIFY
features/communities/{CommunityService,useCommunity,permissions}.ts, ui/*Http*.vue, CreateCommunityPrompt.vue	HTTP communities/members	replaced by relay relay_members + kinds 9030-9033	REMOVE LATER

File	Current role	Target role	Action
<code>.env.example</code> , <code>.env.local</code>	<code>VITE_OKTA_*</code> , <code>SWF_BUZZ_OKTA_*</code> , <code>VITE_SWF_BACKEND_URL</code>	<code>VITE_RELAY_URL</code> only	MODIFY

Tauri (SWF: `src-tauri/`)

File	Current role	Target role	Action
<code>src/auth/oidc.rs</code> , <code>auth/mod.rs</code>	PKCE, JWKS, backend bootstrap, Okta deep-link delivery	none	REMOVE LATER
<code>src/commands/auth.rs</code>	<code>start_okta_login</code> , <code>okta_logout</code>	none	REMOVE LATER
<code>src/commands/secure_storage.rs</code>	generic keychain get/set/delete for <code>nip46_*</code> , <code>swf_session_token</code>	replaced by identity module; generic commands should not expose the identity key to JS	MODIFY (shrink)
<code>src/storage/secure_store.rs</code>	keyring wrapper, service <code>swf-buzz</code>	store the identity nsec	KEEP (reuse)
<code>src/lib.rs</code>	registers Okta commands, single-instance + deep-link handlers wired to <code>oidc</code>	register identity commands; deep-link handler for <code>swfbuzz</code>	MODIFY
<code>tauri.conf.json</code>	deep-link scheme <code>com.okta.trial-7050986</code> ; CSP allows <code>https: wss: ws:</code>	scheme <code>swfbuzz</code> ; tighten CSP later	MODIFY
<code>Cargo.toml</code>	<code>jsonwebtoken</code> , <code>request</code> (blocking), <code>rand</code> , <code>sha2</code> , <code>base64</code> , <code>url</code> , <code>keyring</code>	add <code>nostr</code> (0.44, features <code>nip44</code> , <code>nip49</code>), <code>zeroize</code> ; drop Okta-only crates	MODIFY later
<code>capabilities/default.json</code>	<code>core:default</code> , <code>opener:default</code>	app commands need no extra entry (INFERRED : default Tauri 2 app-manifest behaviour, <code>build.rs</code> is plain <code>tauri_build::build()</code>); verify at implementation	KEEP / verify

Backend (SWF: `backend/`) — the whole crate is Okta/Application-User specific for humans:

`src/{auth,jwks,token,models,config,state,error,invite_authz,community_authz,channel_authz,realtime}.rs`,
`src/routes/*`, `src/repo/*`, `migrations/0001-0007`. **Action: FREEZE now, REMOVE LATER (entire crate)**. Use `*_authz.rs` only as a reference for permission rules already mirrored by the relay.

6. File-by-file Nostr identity dependency map

File / group	Current role	Target role	Action
<code>features/signing/types.ts</code> (<code>SigningService</code>)	interface: <code>getPublicKey</code> , <code>signEvent</code> , <code>nip44Encrypt/Decrypt</code>	unchanged contract	KEEP
<code>features/signing/signingServiceRegistry.ts</code>	active signer registry	unchanged	KEEP
<code>features/signing/signingService.tauri.ts</code>	—	invokes Rust identity commands	NEW

File / group	Current role	Target role	Action
features/signing/signingService.dev.ts	in-webview key (fixed dev key; Okta-derived key)	none (dev override moves to Rust env override in debug builds)	REMOVE LATER
features/signing/signingService.nip46.ts	NIP-46 bunker client	none (bunker excluded)	REMOVE LATER
services/RelayConnectionService.ts	nostr-tools relay, NIP-42 via onauth, backoff, publish / subscribe	same; connect after identity load	KEEP (minor)
services/publish.ts, services/relayQuery.ts	sign+publish, one-shot queries	same	KEEP
services/nip98.ts	kind 27235 with u, method, nonce — no payload tag	add payload (sha256 body) for POST	MODIFY
protocol/* (messages, threads, nip10, reactions, presence, typing, dm, channels, membership, relayMembers, profile, moderation, kinds, types)	event builders/parsers verified vs relay	same	KEEP
protocol/invites.ts, features/invites/*, components/InvitesPanel.vue	legacy kind:9009 channel-invite stub, no importers	none	REMOVE LATER
features/channels/{ChannelService,useChannels,useChannelMembers,useJoinChannel,useCreateChannel,useChannelMemberActions}	Nostr channels	primary	KEEP
features/messages/{MessageService,useSendMessage,useChannelMessages}	kind:9	primary	KEEP
features/threads/{ThreadService,useThread,useThreadSummaries}	NIP-10 threads	primary	KEEP
features/reactions/*	kind:7	primary	KEEP
features/dm/{DmService,Kind41010Transport,DmTransport,use*}	kind:41010 DMs	primary	KEEP
features/presence/*	presence, typing	primary	KEEP
services/ProfileService.ts, composables/useProfile.ts	kind:0 profile by pubkey	primary; add profile write at onboarding	KEEP / EXTEND
features/community-members/{RelayMembersService,permissions,useCommunityMembers}	roster from kind:13534, kinds 9030-9033	authoritative community role	KEEP
features/moderation/*	NIP-98 reads	keep (needs nip98.ts unchanged for GET)	KEEP
features/platform-admin/*	admin console (optional host)	unknown	UNKNOWN
features/agents/*, protocol/agents.ts, stores/agentActivity.ts	agent activity display; observer frames decrypted with the human signer	keep (boundary \$20)	KEEP
views/ChannelsView.vue, views/DmView.vue	legacy Nostr screens	become the primary screens	KEEP

File / group	Current role	Target role	Action
views/CommunityChannelsView.vue , views/CommunityDmView.vue , features/*/use*Http.ts , *ServiceHttp.ts	HTTP backend UI	none	REMOVE LATER

Reuse verdict (estimate, not a measured count): of the 90 non-test source files that reference Nostr terms, the large majority (all `protocol/*`, the channel/message/thread/reaction/DM/presence/profile/moderation/agent services and views) are reused unchanged; the change surface is the auth/signing/onboarding/invite layer plus removals.

7. Tauri identity migration plan

New module `src-tauri/src/identity/` (**behavioural port of OLD BUZZ, not a copy**):

Piece	Port from	SWF specifics
<code>state.rs</code> : Keys in a Mutex, IdentityStorage, RecoveryState	<code>app_state.rs</code> , <code>identity_storage.rs</code>	keep the same enum and recovery semantics
<code>resolve.rs</code> : env → keyring → file → generate; marker file; keyring-locked / identity-lost	<code>app_state.rs</code> : 251-620	env override debug builds only ; keyring service <code>swf-buzz</code> (never <code>buzz-desktop</code>)
<code>file_store.rs</code> : <code>identity.key 00600</code> (Windows: user-profile ACL) + quarantine of corrupt files	<code>app_state.rs</code> : 625-700	Windows has no <code>00600</code> ; document ACL behaviour (UNCLEAR : needs a Windows test)
<code>commands.rs</code> : <code>get_identity</code> , <code>sign_event</code> , <code>nip44_encrypt/decrypt</code> , <code>get_nsec</code> , <code>import_identity</code> , <code>create_ncryptsec_backup</code> , <code>verify_ncryptsec_backup</code> , <code>save_ncryptsec_copy</code> , <code>persist_current_identity</code> , <code>sign_out</code>	<code>commands/identity.rs</code>	drop agent/observer/ <code>build_observer_control_event</code> (agent scope §20) unless required
<code>key_backup.rs</code>	<code>key_backup.rs</code>	NIP-49, script cap on import, local-only

`get_identity` returns {pubkey, npub?, storage, recovery} and **never the secret**. `get_nsec` is the only secret-returning command and is user-initiated (backup screen).

8. Key generation / storage migration plan

1. First launch: `Keys::generate()` in Rust → save to keyring under service `swf-buzz`, name `identity_nsec`; write the migration marker; **no plaintext file** unless the keyring is unavailable.
2. Later launches: same key loaded. Public key = identity everywhere (`relay_members.pubkey`).
3. **No derivation from any external identifier** (removes the Okta-`sub` key issue found in the runtime audit).
4. Existing dev/Okta-derived identities are **not migrated**: they were never real user keys. Users start with a fresh key; roles must be re-granted on the relay (D-6).
5. Import: accept `nsec`, hex, or `ncryptsec` + password. Backup: NIP-49 file, password ≥ generator default. Both in the onboarding flow (Vue port of `BackupStep`, `NostrKeyImportForm`, `DownloadKeyStep`, `NsecMaskedDisplay`).
6. Keyring collision safety: OLD BUZZ (installed on this machine) uses service `buzz-desktop`; SWF's `swf-buzz` is distinct. **CONFIRMED** (SWF: `storage/secure_store.rs: SERVICE_NAME="swf-buzz"`).

9. NIP-42 migration plan

- **Keep the existing TS implementation:** `RelayConnectionService` wires `relay.onauth` → `getActiveSigningService().signEvent(...)` (SWF: `RelayConnectionService.ts:114-160`), already verified against the real relay ("genuine NIP-42 AUTH frame... captured", `E2E_TEST_RESULTS.md`).
- Change: the signer behind it becomes `TauriSigningService` (Rust signs kind 22242). Tags `relay / challenge` are produced by nostr-tools; relay verifies at `handlers/auth.rs:87-92`.
- OLD BUZZ instead runs the socket in Rust. **Recommendation: do not port that** (SWF decision D5 keeps the socket in TS; less new code). Trade-off noted in §30.
- Connect only after `get_identity` succeeds; on `restricted: not a relay member` show the "join with invite" state (port of `MembershipDenied.tsx`).

10. NIP-98 migration plan

- Extend `services/nip98.ts`: add optional `body` → `["payload", sha256hex(body)]`; keep `nonce`. Required by the relay for POSTs (OLD: `api/invites.rs:250-261`, `require_payload: true`).
- **u tag must equal** `{http|https}://{tenant.host()}{path}` — scheme from whether the relay's configured URL is `wss` (OLD: `api/bridge.rs:214-225`). SWF derives it from the community relay URL (`ws`→`http`, `wss`→`https`, host including port).
- Replay: relay marks event ids; `nonce` keeps ids unique. Time skew tolerance is the relay's; SWF just uses current time.
- Existing users of `nip98.ts` (moderation/admin GET reads) keep working (payload only when a body exists).

11. Invite creation migration plan

```
Owner/admin UI (existing panel layout)
→ RelayInviteService.createInvite({ttlSecs?, maxUses?})
→ POST {relayHttp}/api/invites Authorization: Nostr <NIP-98 with payload>
Relay: role ∈ {owner,admin} else 403; returns {code, expires_at, max_uses, uses_remaining, url}
SWF builds the share link ITSELF: swfbuzz://join?relay=<wss-url>&code=<code> (ignore relay `url`)
```

Reuse: `CreateInvitePanel.vue` UI, `useCreateInvite` shape (mutation returning `code/url/expiresAt/maxUses`).
Bounds differ: relay ttl **60 s–30 d** (SWF UI assumed 1 h–30 d), `max_uses` 1–10 000. **No revoke and no preview endpoint exist on the relay** → remove those UI affordances (SWF's backend had them). Verified: only `mint`, `claim`, `accept-policy`, `join-policy` routes exist (OLD: `api/invites.rs`).

12. Invite claim migration plan

```
swfbuzz://join?relay=...&code=... (or paste box)
→ Rust deep-link handler parses + queues (survives cold start) → TS drains
→ confirmation dialog: "Join <relay host>?" (show host; user must accept before any signing)
→ identity exists? yes → continue; no → onboarding first (pending join is kept)
→ optional join policy: GET /api/join-policy → accept-policy → receipt
→ POST /api/invites/claim {code, policy_receipt?} (NIP-98 signed by the user's key)
→ joined | already_member | invite_invalid | invite_expired | invite_exhausted | join_policy_required
→ connect NIP-42 → relay_members gate passes → enter community
```

Reuse: `pendingInvite.ts` (extend to `{relay, code}`), error-message mapping idea from `InviteLandingView.vue`, the "claim then navigate" structure. Behaviour to match: idempotent `already_member`, role `member`, rate limit 10/min/pubkey (server-side). **CONFIRMED** (OLD: `api/invites.rs:361-515`).

13. Community membership migration plan

- **Authority moves to the relay:** `relay_members(community_id, pubkey, role)` + kinds 9030 add / 9031 remove / 9032 role / 9033 icon. SWF already has `RelayMembersService` (roster from kind:13534) and role rules verified against a real relay (`E2E_TEST_RESULTS.md`).
- Community role for UI gating: `resolveMyRole(members, pubkey)` — **already the current** ready **gate**, so no new mechanism is needed.
- **Community creation / owner bootstrap (D-1):** not an in-app action on the relay. Options in §33.
- Same pubkey in several communities = several relay hosts; SWF today has a single `VITE_RELAY_URL` (D-2).

14. Channel authorization migration plan

Relay rules to rely on (not reimplement): write allowed iff channel member **or** channel `open`; read filtered by `accessible_channel_ids`; open channels self-join (kind 9021); private needs invitation (9000); last-owner protection; community owner $\neq$ channel owner (OLD: `handlers/ingest.rs:741-770`, `side_effects.rs:1950-1985`, `req.rs:110-195`). SWF's `channelPermissions.ts` already mirrors the client-side rules. Note this **differs from SWF's HTTP backend** (which required explicit membership even for open channels): switching restores OLD BUZZ behaviour.

15-19. Message, thread, reaction, DM, profile plans

Area	Plan	Action
Messages	Use the existing Nostr <code>MessageService</code> / <code>useSendMessage</code> (kind 9, <code>h</code> tag). No new work beyond the signer swap	KEEP
Threads	Existing NIP-10 <code>ThreadService</code> (one real bug already fixed per <code>E2E_TEST_RESULTS.md</code> §6)	KEEP
Reactions	Existing kind:7 <code>ReactionService</code> (highest-confidence item in the E2E doc)	KEEP
DMs	Existing kind:41010 <code>DmService</code> ; the profile → Message button already targets it (<code>UserProfilePanel.vue:31</code>)	KEEP
Profile	Keyed by pubkey. Add: profile <i>creation</i> (kind:0) in onboarding (OLD BUZZ <code>ProfileStep</code> , <code>commands/profile.rs:40-80</code>); display via existing <code>ProfileService</code>	EXTEND
Presence / typing	Existing services	KEEP
Notifications	Not implemented in SWF today (<code>UNCLEAR</code> scope)	Decision D-8

Removed as a consequence: all `*ServiceHttp.ts`, `use*Http.ts`, `/community*` views, `RealtimeService` (their features exist on the Nostr path).

20. Agent boundary

- **Human identity** → **OLD BUZZ model** (this plan).
- **Remote/server-side agents** → **keep on the Nostr relay** (D10 already decided this): `features/agents/*`, `protocol/agents.ts`, `stores/agentActivity.ts`, `AgentActivityBar.vue`, kind:30177 detection, mention candidates.

- **One coupling to preserve deliberately:** agent observer frames are NIP-44-encrypted to the *human's* pubkey, decrypted through the signer (`AgentActivityService.ts:handleFrame` → `signer.nip44Decrypt`). With the Rust key this becomes an `nip44_decrypt` Tauri command (**needed** in the identity module, unlike the Okta-derived key where the webview did it). If agent-observer display is out of v1 scope, this command can wait.
- **Local/managed agents and runtime:** excluded; SWF has none (verified §22).

21. GitHub exclusion boundary

`grep -i github` over `SWF src, src-tauri/src, backend/src, backend/migrations` → **no matches**; no Tauri command, route, service or model relates to GitHub/projects. **Nothing to remove.** Never port from OLD BUZZ: `desktop/src/features/projects` (212 files), `git-credential-nostr`, `git-sign-nostr`, `relay api/git/*`. **CONFIRMED.**

22. Features to keep (behaviour parity targets)

Identity generation/storage/import/backup; onboarding + profile; NIP-42; NIP-98; communities (as relay tenants); membership + roles (owner/admin/member); invites (create/claim); channels (open/private) + channel membership; text messages; threads; reactions; DMs; profiles; presence; typing; moderation (already present); notifications (D-8).

23. Features to exclude

GitHub / projects / git hosting; local & managed agents; agent runtime; huddles/voice; canvas; workflows; terminal; mesh compute/relay-mesh; mobile push & device pairing; BuilderLab hosted-community coupling; developer tooling crates (`buzz-test-client`, `buzz-conformance`, `benchmarks`, `harness`). Borderline pending product decision: forum, pulse, reminders, search, custom emoji, GIFs, user status.

24. Files that can be reused

Signing interface + registry; `RelayConnectionService`, `publish`, `relayQuery`; all of `protocol/*` (except legacy invites); all Nostr feature services and composables (channels, messages, threads, reactions, dm, presence, profile, community-members, moderation, agents); `ChannelsView/DmView` and their components; `pendingInvite.ts`; `CreateInvitePanel.vue` (UI); `storage/secure_store.rs`; single-instance + deep-link plugin wiring in `lib.rs`; the vitest suites (81 passing tests per `E2E_TEST_RESULTS.md`, to be re-run).

25. Files that must be rewritten

`useAuth.ts`; `LoginView.vue`; `stores/session.ts` (trim); `app/router/index.ts` (guard/routes); `InviteLandingView.vue` → join flow; `communities/InviteService.ts/useInvites.ts` → relay+NIP-98; `services/nip98.ts` (payload); `lib.rs` (commands/deep link); `commands/secure_storage.rs` (shrink); `tauri.conf.json` (scheme); `.env*` and `app/config.ts`.

26. Files that should be removed later (after the test plan passes)

Frontend: `OktaCallbackView.vue`, `features/auth/authService.okta*.ts`, `oktaBrowserFlow.ts`, `authService.dev.ts`, `signingService.dev.ts`, `signingService.nip46.ts`, `services/ApiClient.ts`, `services/RealtimeService.ts`, all `*ServiceHttp.ts/use*Http.ts`, `CommunityChannelsView.vue`, `CommunityDmView.vue`, `communities/{CommunityService,useCommunity,permissions}.ts`,

communities/ui/*Http*.vue, CreateCommunityPrompt.vue, protocol/invites.ts, features/invites/*, components/InvitesPanel.vue. Tauri: auth/oidc.rs, auth/mod.rs, commands/auth.rs, Okta env handling, jsonwebtoken/blocking request deps. Repo: backend/ (whole crate + its migrations), Okta docs (OKTA_PKCE_SETUP.md, D9/D10 sections marked superseded).

27. Database changes required

- **Relay/OLD BUZZ DB: none** (read-only reference; relay_members, relay_invites, channel_members, events already exist — OLD: migrations/0001, 0025).
- **SWF: none.** The SWF backend's users/sessions/community_*/channels/messages/dm_* tables become unused; no migration is required and none should be run. If the backend is later deleted, its DB is simply dropped.
- Test-environment DB state (not schema): closed-relay config and an owner row (§33).

28. API changes required

API	Change
Relay POST /api/invites, /claim, /accept-policy, GET /api/join-policy	consume as-is from SWF (no relay change)
Relay WS + NIP-42, kinds 9000-9033, 13534, 9, 7, 41010...	consume as-is (already implemented in SWF)
SWF backend /api/*	stop using ; freeze; delete later
New SWF-internal	none (no new server)
Tauri commands	add identity commands (§7); remove start_okta_login, okta_logout later

29. Deep-link changes required

- tauri.conf.json plugins.deep-link.desktop.schemes: ["swfbuzz"] (replace com.okta.trial-7050986 when Okta is removed; both may coexist during transition).
- lib.rs: is_our_deep_link + single-instance and on_open_url handlers deliver to a new deeplink module instead of oidc::deliver_incoming_url; register_all() already runs at startup for unbundled Windows/Linux dev builds (CONFIRMED, lib.rs setup).
- Parse swfbuzz://join?relay=ws(s)://host[:port]&code=<v2 code>[&policy_receipt=] (port parse_join_deep_link, parse_websocket_relay_param: validate scheme and host, require both params).
- Queue in Rust so a cold-start link is not lost; frontend drains after identity is ready; **explicit user confirmation** before signing (§30).
- **Do not register** buzz://: it belongs to the installed OLD Buzz app on this machine. CONFIRMED (buzz-desktop.exe present; landing page uses buzz://).

30. Security considerations

1. **Key never in the webview.** Today it is (fixed dev key / Okta-derived). Target fixes this; Rust signs on request. Remove the SHA-256(okta_sub) derivation entirely.
2. sign_event **is a signing oracle** for any webview code (OLD BUZZ has no kind allowlist either, commands/identity.rs:107-136). Mitigate: keep the CSP tight (SWF's current CSP allows connect-src https:

- wss: ws: — narrow it to configured relays), no remote scripts, and consider an allowlist of kinds/URLs after parity.
3. **Deep-link confirmation.** A crafted `swfbuzz://join?relay=evil` link could make the app sign a NIP-98 claim for an attacker host. The signature is bound to that URL only, but show the host and require consent (OLD BUZZ stages and acknowledges links before acting, `communityOnboarding.tsx:37-58`).
 4. **Backup material stays local** (NIP-49, no network path); cap script `log_n` on import (DoS), as OLD BUZZ does (`key_backup.rs`).
 5. **Logout semantics (D-5).** OLD BUZZ sign-out wipes the identity; without a backup the user loses it. Require a backup prompt and a typed confirmation, or make "sign out" not delete the key.
 6. **Env override (`SWF_BUZZ_PRIVATE_KEY`) debug builds only.** OLD BUZZ allows it in release builds too; a stray env var would silently change identity.
 7. **Windows key file protection** has no `00600`; prefer keyring-only and treat the file fallback as best-effort (**UNCLEAR** until tested).
 8. **Public key is the identity** ⇒ no account recovery beyond backup/import. Product/support implication.
 9. **Invite secret hygiene:** treat `code` as a bearer secret; never log it; relay stores only its SHA-256. Rate limit exists server-side (10/min/pubkey).
 10. Old Buzz's relay runs **open** by default; membership is enforced only when `BUZZ_REQUIRE_RELAY_MEMBERSHIP=true` — production must set it.

31. Step-by-step implementation order (recommended)

Each phase ends with a gate; do not start the next until it passes.

#	Phase	Work	Gate
0	Environment	Run the local relay <i>closed</i> with a known owner (env-only, no edits to OLD BUZZ): <code>BUZZ_REQUIRE_RELAY_MEMBERSHIP=true</code> , <code>RELAY_OWNER_PUBKEY=<hex></code> ; host aliases already seeded	Two test identities can be created; non-member is rejected at NIP-42
1	Rust identity layer	<code>identity/</code> module + unit tests ported from OLD BUZZ (fake store, corrupt/locked/lost states)	<code>cargo test</code> for resolve order, generate-once, reload same key, import/backup round-trip
2	TauriSigningService + login rewire	new signer; <code>useAuth</code> loads identity, connects relay, resolves role; Okta path made unreachable (not deleted)	App starts with no Okta config; NIP-42 succeeds; same pubkey after restart
3	Onboarding UI	Vue screens: welcome/create, profile (kind:0), backup, import, keyring-locked/lost	First-launch and returning-launch flows verified by hand + CDP
4	NIP-98	payload tag support + tests against relay expectations	Mint/claim requests accepted by the relay
5	Membership + roles	make relay roster the only source of role; hide HTTP community UI	Roles match the E2E doc's rules on the real relay
6	Invite create	<code>RelayInviteService</code> , panel wiring, <code>swfbuzz://</code> link generation	Owner gets a code; non-admin gets 403
7	Deep link + claim	scheme, queue, confirm dialog, claim, join-policy, error states	User B joins as <code>member</code> ; repeat claim → <code>already_member</code>
8	Channels	make <code>ChannelsView</code> primary; open/private semantics	Matrix from §14 passes
9	Messages / threads / reactions	verify existing services with the new signer	Two-user exchange on real relay

#	Phase	Work	Gate
10	DMs / profile / presence / typing	verify; profile→DM	Two-user DM on real relay
11	Retire HTTP path	remove <code>*Http</code> , <code>ApiClient</code> , <code>RealtimeService</code> , <code>/community*</code> routes	App has no dependency on <code>swf-buzz-backend</code>
12	Remove Okta + backend	delete Okta files, Rust auth module, env vars, <code>backend/</code> , unused crates	<code>npm run build</code> , <code>cargo check</code> , all tests green
13	Hardening + docs	CSP, kind allowlist decision, update <code>DECISIONS.md</code> (D2/D3/D9/D10 superseded), <code>LOCAL_DEVELOPMENT.md</code> , <code>.env.example</code>	Definition of Done (§34)
—	<i>Remove GitHub / local agents</i>	No-op (nothing exists). Keep the exclusion list as a review checklist	n/a

Difference from the sketched order: Okta is **disabled at phase 2 but deleted at phase 12**, and "invite create" precedes deep-link/claim only in code order; both are tested together at phase 7.

32. Risks

#	Risk	Likelihood / Impact	Mitigation
R1	No way to create the first owner from the app	Certain / High	D-1; document <code>RELAY_OWNER_PUBKEY</code> bootstrap; show the user's pubkey/npub in onboarding for the operator
R2	Legacy Nostr screens were mostly code-audited only , not click-tested on a real relay (only NIP-42 connect and member management were)	Medium / Medium	Phase 8-10 gates; re-run existing tests; CDP click-through
R3	Relay invite landing page hardcodes <code>buzz://</code>	Certain / Medium	SWF builds its own <code>swfbuzz://</code> link; optional SWF landing page later
R4	No relay preview/revoke for invites	Certain / Low	Remove UI; show relay host on the join dialog
R5	Losing the key = losing the account	Medium / High	Backup step, warnings, import
R6	Windows keyring/file behaviour differs from macOS/Linux	Medium / Medium	Test on Windows first; keyring primary
R7	Signing oracle in the webview	Low / High	CSP, no remote content, later allowlist
R8	Coexistence with installed OLD Buzz (keyring, deep link, ports)	Low / Medium	Distinct keyring service and scheme (already planned)
R9	Removing the HTTP UI drops two things the relay has no equivalent for: invite preview (community name) and invite revoke	Low / Low	Accept; show the relay host on the join dialog; revoke is unavailable
R10	<code>nostr</code> crate version drift vs OLD BUZZ (0.44)	Low / Low	Pin 0.44 with <code>nip44</code> , <code>nip49</code>
R11	Tauri webview origin <code>http://tauri.localhost</code> vs relay CORS/origin rules	Low / Medium	Already worked for WS (real relay, <code>E2E_TEST_RESULTS.md</code>); re-check for HTTP <code>fetch</code> to <code>/api/invites</code> (CORS) — UNCLEAR

#	Risk	Likelihood / Impact	Mitigation
R-12	u-tag mismatch (host/port/scheme) breaks NIP-98	Medium / Medium	Derive from the tenant host rule (\$10); unit test

33. Testing plan and decisions

Decisions needed before Phase 0 (blocking):

ID	Decision	Recommendation
D-1	How is a community created and its first owner set?	Self-host/dev: RELAY_OWNER_PUBKEY + host seed. Production: operator provisioning (POST /operator/communities) via existing buzz-admin/operator tooling. Remove SWF's in-app "create community"
D-2	One relay/community per install, or a community switcher (relay list)?	Start with one (VITE_RELAY_URL); design storage as a list so a switcher can follow
D-3	Deep-link scheme name	swfbuzz
D-4	Keep TS-owned WebSocket (D5) vs Rust-native like OLD BUZZ	Keep TS
D-5	Sign-out behaviour	Do not wipe by default; separate "Reset identity" with backup prompt
D-6	Existing users/roles from the Okta/dev era	Not migrated; re-grant on the relay
D-7	Show/hide raw nsec	Only in the backup screen, behind confirmation
D-8	Notifications and borderline features in v1?	Defer; decide after parity

Test layers

- Rust unit tests:** resolve order (env→keyring→file→generate); generate-once/reload-same-key; corrupt file quarantine; keyring-locked and identity-lost states; import (nsec/hex/ncryptsec+wrong password); backup round-trip; persist_current_identity lost-only.
- TS unit tests:** TauriSigningService (mock invoke), nip98 payload/ u / method / nonce , deep-link parse (valid/invalid/hostile), pending-join store, error mapping; keep the existing unit and integration suites green (E2E_TEST_RESULTS.md reports 71 unit + 10 integration passing; re-run to get current counts).
- Integration (real local relay, closed mode, two identities A owner, B new):**
 - non-member B connects → restricted: not a relay member;
 - A mints invite → 200; B mints → 403;
 - B claims → joined , role member ; claim again → already_member ; bad/expired/exhausted codes; 11th claim in a minute → 429;
 - B connects → allowed; A changes B's role (9032); A removes B (9031) → B rejected on reconnect;
 - channels: open self-join works, private join denied; community owner without channel membership cannot read a private channel;
 - messages, threads, reactions, DM between A and B; profile→DM; presence/typing; reconnect after relay restart.

10. **Windows manual/CDP:** first launch (no Okta env), restart same pubkey, keyring reset scenario, backup/import to a fresh profile, `swfbuzz://` link with app closed and open.
11. **Regression:** `npm run typecheck && lint && test && build; cargo check && clippy && fmt --check`.
12. **Negative security tests:** deep link to unknown relay requires consent; no secret in logs; `get_identity` has no secret; env override ignored in release.

34. Definition of Done

1. Fresh install with **no Okta or backend configuration** starts, generates a key in Rust, stores it under `swf-buzz`, and shows the same pubkey after restart.
2. The key never appears in JS except via the explicit backup command.
3. NIP-42 connect and NIP-98 requests are signed by the Rust key.
4. Owner (bootstrapped via `RELAY_OWNER_PUBKEY`) creates an invite; a second identity joins via `swfbuzz://` and becomes `member` in `relay_members`; repeat claim is idempotent.
5. Non-members are rejected; roles gate UI exactly as on the relay.
6. Channels (open/private), messages, threads, reactions, DMs, profiles, presence and typing work between two identities on the real relay.
7. Identity import and NIP-49 backup work; lost/locked-keyring states are handled.
8. No code path references Okta, `okta_sub`, the SWF backend, `ApiClient`, NIP-46, or the dev/derived signer; those files are deleted.
9. No GitHub/project/local-agent code exists (already true) and the exclusion checklist is documented.
10. All automated checks and the integration scenarios in §33 pass; `docs/` updated (DECISIONS, `LOCAL_DEVELOPMENT`, `.env.example`).

Appendix A — Evidence added in this phase

Fact	Evidence
Relay is open by default; no owner configured locally	OLD: <code>crates/buzz-relay/src/config.rs:670-672</code> ; local <code>.env</code> has neither <code>BUZZ_REQUIRE_RELAY_MEMBERSHIP</code> nor <code>RELAY_OWNER_PUBKEY</code>
<code>buzz-admin add-member</code> cannot create owners	OLD: <code>crates/buzz-admin/src/main.rs:45-56</code>
Landing page served only with <code>web_dir</code> ; hardcoded <code>buzz://join</code>	OLD: <code>router.rs:158-163,239-246</code> ; <code>web/.../InvitePage.tsx:113</code>
NIP-98 expected URL rule	OLD: <code>crates/buzz-relay/src/api/bridge.rs:214-225</code>
Old desktop deps: <code>nostr 0.44 [nip44,nip49]</code> , <code>keyring 3.6.3</code> , <code>zeroize</code>	OLD: <code>desktop/src-tauri/Cargo.toml:96,42-67,100</code>
<code>sign_event</code> / <code>create_auth_event</code> shapes	OLD: <code>commands/identity.rs:107-136, 641-666</code>
SWF signer contract, NIP-42 wiring, <code>nip98.ts</code> gap	SWF: <code>features/signing/types.ts</code> , <code>services/RelayConnectionService.ts:114-160</code> , <code>services/nip98.ts</code>
SWF keyring service <code>swf-buzz</code> , deep-link/single-instance wiring	SWF: <code>src-tauri/src/storage/secure_store.rs</code> , <code>lib.rs:20-78</code>

Fact	Evidence
Verified vs code-audited status of the Nostr path	SWF: docs/E2E_TEST_RESULTS.md:3-72, 87-200

Scope note: no application source, package, Cargo, environment, Okta, database or API file was modified. Files created: this plan and its PDF rendering.